Offensive / CPTC reference sheet (your event's rules override this)

Mindset

`You win on the REPORT`	coverage + ratings + remediation + summary
`Prove, do not destroy`	minimal, redacted proof; never dump real data
`Write as you go`	host, command, output, time — for every finding
`Stay in scope`	read the RoE; out-of-scope = disqualification
`Rate honestly`	inflated severities lose points

Phases

`1 Recon`	what exists (nmap)
`2 Enumerate`	dig into each service
`3 Exploit`	prove with least force
`4 Post-exploit`	loot, creds, lateral
`5 Report`	write up everything confirmed

Recon

`nmap -sV RANGE`	hosts, ports, versions
`nmap -p- HOST`	all 65535 ports
`nmap -sC HOST`	default safe scripts
`nmap -Pn HOST`	skip ping
`masscan`	fast sweep of big ranges

Web

`gobuster/ffuf/feroxbuster`	hidden paths and files
`whatweb / nikto`	server + quick checks
`sqlmap -u URL --data=P`	SQL injection
`Burp Suite`	intercept and tamper
`nuclei`	templated known-issue checks
`curl /v2/accounts/<id>`	IDOR: change the id
`git-dumper URL/.git`	exposed repo and .env

Network / services

`smbclient -L //HOST -N`	SMB shares, null session
`smbmap / enum4linux`	shares and users
`snmpwalk -v2c -c public HOST`	default SNMP string
`sslscan HOST`	weak TLS

Exploit / creds

`searchsploit NAME`	known exploits
`curl -u admin:admin URL`	default creds
`hydra / medusa`	online password guessing
`hashcat -m 18200 f wl`	crack AS-REP offline
`metasploit`	exploit framework

Active Directory

`impacket-GetNPUsers -no-pass`	AS-REP roast
`hashcat -m 18200`	crack the AS-REP hash
`crackmapexec smb HOST -u U -p P`	spray; (Pwn3d!) = local admin
`impacket-secretsdump`	dump hashes once admin
`Reuse the credential`	lateral movement

Risk matrix (Likelihood x Impact)

`High x High`	Critical
`High x Med / Med x High`	High
`Med x Med / Low x High / High x Low`	Medium
`everything else`	Low
`Likelihood`	how easy / probable
`Impact`	how bad if it happens

Remediation: root cause

`SQL injection`	parameterized queries, NOT a WAF alone
`RDP exposed`	off the internet, VPN + MFA, NOT a new port
`IDOR`	server-side object authorization
`Default creds`	change them; disable unused accounts
`Known CVE`	patch / upgrade the product
`Open bucket`	make private; least privilege

Executive summary

`Plain business risk`	breach, ransomware, data, downtime
`Name the 1-2 worst`	in words, not jargon
`A timeframe`	e.g. within 72 hours
`What improves once fixed`	
`NO`	ports, CVE ids, CVSS